

09	Malicious Macro & Spear Phishing (악성 매크로 및 스피어 피싱)
취약점 개요	
점검 내용	외부에서 유입되는 이메일 첨부파일(문서 파일 등)의 악성 매크로 포함 여부 및 메일 발신자 검증 시스템 확인
점검 목적	내부 직원을 대상으로 한 사회공학적 기법을 통해 내부망 PC가 악성코드에 감염되고 제어권이 탈취되는 것을 방지함
보안 위협	피해자가 악성 매크로가 포함된 문서를 열람 시, 공격자에게 리버스 커넥션(Reverse Connection)이 연결되어 내부 PC의 제어권이 탈취됨
참고	- 악성 문서 열람 → 콘텐츠/매크로 사용 허용 → 악성코드 실행 및 공격자 세션 맺음 [판별법] - 인터넷이나 메일을 통해 다운로드한 Word/Excel 문서 실행 '콘텐츠 사용' 또는 '매크로 포함' 버튼 클릭 시 경고 없이 백그라운드 프로세스(cmd.exe, powershell.exe 등)가 실행되는지 확인 - 외부 IP로 비정상적인 네트워크 연결(Reverse Shell)이 시도되는지 확인
점검대상 및 판단기준	
대상	메일 보안 솔루션, 사내 임직원 PC (오피스 문서 보안 설정)
조치방법	- 출처가 불분명한 메일 열람 및 링크 클릭 금지 교육 수행 - 사내 PC의 MS Office 프로그램 내 '모든 매크로 제외(알림 표시)' 또는 '디지털 서명된 매크로만 포함' 설정 강제 적용 - 이메일 APT 방어 솔루션 도입으로 악성 첨부파일 사전 차단
점검 및 조치사례	
1. 취약한 동작 확인 - 피해자 PC에서 수신된 REPORT.doc 실행. - 상단에 노란색 알림 표시줄로 [콘텐츠 사용] 버튼이 나타나며, 클릭 즉시 공격자 PC(칼리 리눅스)와 세션이 연결됨.	

2. 보안 방법 및 조치

- 기술적 조치와 관리적(사용자 교육) 조치가 병행되어야 합니다.
- 조직 내 AD(Active Directory) 환경인 경우, 그룹 정책(GPO)을 통해 인터넷에서 다운로드한 오피스 파일의 매크로 실행을 원천 차단해야 합니다.

[시스템/정책 조치]

- Windows 그룹 정책(GPO) 설정

1. gpedit.msc (로컬 그룹 정책 편집기) 실행

2. [사용자 구성] -> [관리 템플릿] -> [Microsoft Word 2016] -> [Word 옵션] -> [보안] -> [보안 센터]로 이동

3. "인터넷에서 가져온 Office 파일에서 매크로 실행 차단" 정책을 '사용(Enabled)'으로 변경

4. (효과) 웹이나 이메일(MOTW 태그가 붙은 파일)에서 다운받은 문서의 매크로는 사용자가 임의로 실행할 수 없게 됨.